Relatório de Impacto à Proteção de Dados Pessoais de Cars Galore

Versão	Data	Descrição das alterações
1.0	10/10/2026	Primeira versão

O Relatório de Impacto à Proteção de Dados Pessoais (RIPD) explica como o tratamento pode afetar as pessoas e como esses riscos são reduzidos. Este relatório usa a estrutura recomendada pela ANPD. O conteúdo mínimo inclui dados tratados, métodos de coleta/segurança e análise das salvaguardas.

1. Responsáveis e contexto

Item	Preenchimento inicial
Controlador	Cars Galore
Encarregado ou canal responsável	Funcionário (funcionario@carsgalore.com)
Responsável técnico	Funcionário (funcionario@carsgalore.com)
Operadores/fornecedores	AWS para hospedagem, banco, identidade, mensagens hospedadas e logs; confirmar entidade contratada, obrigações e demais operadores.
Processo avaliado	Cadastro e aprovação de compradores; autenticação; reserva, compra e registro de pagamentos de veículos.
Sistemas	`sub3-compradores`, `sub3-principal`, `sub3-financeiro`, `sub3-orquestrador`, RDS PostgreSQL, Cognito, Kafka em Fargate e CloudWatch.
Motivação	Levantamento preventivo de riscos relativos a identificação, endereço, autenticação e histórico de compras.
Ambiente e escala	Projeto acadêmico.

2. Titulares, dados e ciclo de vida

Titulares: interessados no cadastro, compradores e pessoas associadas às contas internas de acesso. Não foram identificados campos específicos de dados sensíveis.

1. **Coleta:** comprador informa CPF, primeiro/último nome, e-mail e telefone no cadastro. Na reserva, informa placa do veículo que irá adquirir, endereço e CEP; o orquestrador extrai CPF da identidade autenticada. Funcionário informa características e valor dos veículos.
2. **Produção e uso:** sistema gera IDs, estado de autorização, código de pagamento, valores transacionais, status e datas. Funcionário aprova cadastro; Cognito cria a conta; financeiro processa reserva/pagamento; principal associa CPF ao veículo adquirido.
3. **Armazenamento e acesso:** três bancos na mesma instância RDS. Funcionários autorizados recebem cadastro dos compradores pendentes e veículos vendidos com CPF. Compradores consultam/pagam registros cuja titularidade é verificada pelo financeiro.
4. **Transmissão:** APIs REST entre serviços; mensagens Kafka com identificadores e, no resultado de pagamento, CPF/placa; integração administrativa Cognito; logs das aplicações enviados ao CloudWatch.
5. **Fim do ciclo:** não foi identificada rotina de descarte por prazo nas tabelas. Reserva vencida permanece armazenada com novo status. Grupo CloudWatch das aplicações declara sete dias.

Localização: região padrão `sa-east-1`, configurável. Compartilhamento externo observado: infraestrutura AWS. Não foi localizada integração com instituição financeira/PSP Pix.

3. Finalidades, necessidade e justificativas

Processo/dados	Finalidade proposta	Justificativa da necessidade
Cadastro: CPF e nomes	Identificar parte interessada e vincular compras	Necessário para identificar comprador
E-mail e telefone	Contato relacionado à compra, se realizado pelo negócio	Necessário para meio de contato com potencial comprador

Processo/dados	Finalidade proposta	Justificativa da necessidade
Autorização	Habilitar conta e restringir acesso	Necessário para autorizar usuário autorizado a fazer proposta de compra
Endereço e CEP	Documentação financeira	Necessário para documentação financeira.
CPF, veículo, valores, status e datas	Executar e acompanhar reserva/compra	Necessário para dashboard administrativos e contabilidade da empresa

`Autorização` expressa decisão do funcionário sobre habilitação, não consentimento do titular.

4. Medidas de proteção existentes e melhorias necessárias

Esta seção descreve as medidas identificadas no código e nas definições de infraestrutura, a proteção que oferecem e suas limitações. A análise segue a orientação da ANPD sobre salvaguardas e mitigação de riscos no RIPD.

4.1. Medidas identificadas no repositório

Área	Medida identificada	Proteção oferecida e limite da análise
Acesso às operações	O orquestrador autentica usuários por OIDC e restringe operações por papéis. Nas operações de comprador, extrai o CPF da identidade autenticada. O financeiro verifica a titularidade na consulta e no pagamento.	Ajuda a restringir operações aos usuários autorizados e aos registros do próprio comprador. A proteção depende também da segurança das credenciais e das chamadas entre serviços.
Integridade dos registros	Consultas parametrizadas, atualização condicional da venda e controle de versão do pagamento para detectar alterações concorrentes.	Reduz riscos de injeção nas consultas analisadas e de alterações conflitantes em vendas e pagamentos. Não comprova a integridade de todos os fluxos.
Proteção do banco de dados	O CDK configura criptografia do RDS em repouso e conexões JDBC com `sslmode=require`.	Protege o armazenamento e exige conexão criptografada com o banco. Não comprova a proteção dos demais trechos de comunicação.
Armazenamento de credenciais	Credenciais de banco são armazenadas no AWS Secrets Manager e fornecidas às aplicações como segredos.	Evita manter essas credenciais diretamente nas definições das aplicações. Ainda é necessário limitar quais serviços e pessoas podem acessá-las.
Isolamento de rede	As tarefas das aplicações são configuradas em sub-redes privadas, com regras de acesso por grupos de segurança.	Reduz a exposição direta das tarefas à internet. O tráfego interno amplo e a entrada pública por HTTP permanecem como lacunas.
Retenção de logs	O grupo CloudWatch compartilhado pelas aplicações e pelo Kafka tem retenção configurada de sete dias.	Limita a conservação nesse grupo. O prazo não se aplica automaticamente aos dados dos tópicos Kafka, às exportações de logs ou a outros grupos.

4.2. Lacunas e medidas propostas

As medidas abaixo são propostas de melhoria; sua implementação ainda não foi comprovada. Os riscos e as prioridades correspondentes estão detalhados na seção 5.

Lacuna identificada	Melhoria necessária	Risco relacionado
CPF usado como senha permanente no Cognito.	Adotar credencial independente do CPF, convite seguro e troca das credenciais existentes; avaliar autenticação multifator.	R1
Entrada pública pelo balanceador de carga em HTTP; chamadas internas baseadas na confiança da rede e no cabeçalho `X-CPF` Kafka em texto claro.	Habilitar HTTPS na entrada, proteger o transporte interno e autenticar as chamadas e mensagens entre serviços.	R2 e R3
Dados pessoais em respostas, rotas e logs.	Restringir os dados retornados ao necessário, evitar CPF em URLs, mascarar dados pessoais nos logs e revisar os acessos.	R4

Lacuna identificada	Melhoria necessária	Risco relacionado
A seção 3 apresenta justificativas para contatos e endereço; a necessidade e a proporcionalidade da coleta ainda precisam ser validadas no contexto real. Não foi identificada rotina de descarte por prazo nas tabelas analisadas.	Validar a coleta de cada campo frente à finalidade declarada; definir e implementar prazos de retenção e descarte nos diferentes destinos.	R5
Backups automáticos e proteção contra exclusão desabilitados no CDK; divergências de esquema de banco identificadas.	Definir requisitos de recuperação, habilitar as proteções necessárias, testar a restauração e reconciliar os esquemas.	R6
Credencial de banco compartilhada e permissão ampla de tráfego entre tarefas.	Adotar contas e permissões por serviço e restringir as regras de rede às comunicações necessárias.	R7
Aviso de privacidade e procedimento de atendimento aos titulares não localizados no repositório.	Confirmar sua existência na organização; documentar ou criar os mecanismos de informação e atendimento.	R8

5. Avaliação preliminar de riscos aos titulares

Esta avaliação descreve situações que podem causar danos aos compradores e às demais pessoas cujos dados são tratados. As lacunas da seção 4 são o ponto de partida; os efeitos abaixo são possibilidades, sem confirmação de que tenham ocorrido.

5.1. Critérios de avaliação

A análise considera os controles identificados no repositório e usa dois critérios:

- **Probabilidade:** possibilidade de o evento ocorrer, considerando exposição, facilidade de exploração e controles existentes. É classificada como baixa, média ou alta. Quando faltam informações suficientes, fica como “a confirmar”.
- **Impacto:** gravidade do dano à pessoa se o evento ocorrer. É classificado como baixo, médio ou alto. Nesta análise, o impacto é alto quando pode envolver uso indevido da conta, exposição de dados pessoais ou perda e alteração de registros de compra e pagamento.

As classificações são estimativas qualitativas.

5.2. Riscos identificados e possíveis danos

ID	Situação que pode causar o dano	Possível dano ao titular	Probabilidade	Impacto
R1	O CPF é usado como senha permanente no Cognito. Uma pessoa que conheça esse dado pode tentar acessar a conta do comprador.	Acesso indevido à conta, consulta de dados pessoais e realização de operações em nome do comprador.	Alta	Alto
R2	A entrada pública pelo balanceador de carga usa HTTP. Dados e tokens podem ser interceptados durante a comunicação.	Exposição de dados pessoais e uso do token interceptado para acessar a conta.	Média	Alto
R3	As APIs internas confiam na rede e no cabeçalho `X-CPF` o Kafka transmite mensagens em texto claro. Um serviço comprometido pode acessar dados ou enviar chamadas e mensagens falsas.	Consulta ou alteração indevida de dados e associação de operações à pessoa errada.	Média	Alto
R4	CPF e outros dados pessoais aparecem em respostas, rotas ou logs. Acesso excessivo a esses destinos pode expor os dados.	Divulgação indevida da identidade do comprador e de sua associação a veículos ou ao histórico de compras.	Média	Alto
R5	A necessidade dos campos deve ser validada frente às finalidades declaradas na seção 3. Não foi identificada rotina de descarte por prazo nas tabelas analisadas.	Conservação de contatos, endereço e histórico além do necessário, aumentando o período de exposição a uso indevido ou vazamento.	Média	Alto
R6	O CDK desabilita backups automáticos e proteção contra exclusão. Há diferenças entre os scripts SQL e os mapeamentos Java, incluindo a exigência de CPF do comprador em veículos e sua remoção no desfazimento de uma venda.	Perda de cadastros ou histórico e falhas na correção ou no desfazimento de operações, prejudicando o acompanhamento da compra.	Média	Alto

ID	Situação que pode causar o dano	Possível dano ao titular	Probabilidade	Impacto
R7	Os serviços compartilham uma credencial de banco e têm permissão ampla de comunicação interna. O comprometimento de um serviço pode alcançar dados de outros processos.	Exposição ou alteração de dados de cadastro, veículos e pagamentos, ampliando os danos de um incidente.	Média	Alto
R8	O aviso de privacidade e o procedimento de atendimento aos titulares não foram localizados no repositório; sua existência na organização precisa ser confirmada.	Falta de informação sobre o uso dos dados e dificuldade para solicitar acesso, correção ou exclusão, quando aplicável.	Alta	Médio

Em R6, as diferenças nos arquivos não comprovam que o banco implantado use o esquema divergente. É necessário consultar suas restrições efetivas. Em R8, a ausência de documentos no repositório também não comprova sua inexistência na organização.

5.3. Ações recomendadas e responsáveis sugeridos

Os responsáveis abaixo são sugestões de atribuição; sua designação e os prazos devem ser confirmados pelo controlador.

Risco	Ação recomendada	Responsável sugerido
R1	Substituir a senha baseada no CPF, trocar as credenciais existentes, adotar convite seguro e avaliar autenticação multifator.	Equipe responsável pela identidade e autenticação.
R2	Habilitar HTTPS na entrada, redirecionar HTTP para HTTPS e verificar a proteção dos demais trechos de comunicação.	Equipe de infraestrutura.
R3	Autenticar chamadas e mensagens entre serviços, proteger seu transporte e restringir acessos internos.	Equipes de desenvolvimento e infraestrutura.
R4	Retornar apenas os dados necessários, evitar CPF em URLs, mascarar dados pessoais nos logs e revisar e auditar os acessos.	Equipes de desenvolvimento e operações.
R5	Validar a necessidade de cada campo e definir prazos e rotinas de descarte nos bancos, no Cognito, nas mensagens e nas cópias pertinentes.	Responsáveis pelo negócio e pela privacidade, com apoio técnico.
R6	Definir requisitos de recuperação, habilitar as proteções necessárias, testar a restauração e alinhar o esquema efetivo do banco aos fluxos da aplicação.	Equipes de infraestrutura, banco de dados e desenvolvimento.
R7	Usar contas e permissões de banco por serviço e limitar a comunicação interna às conexões necessárias.	Equipes de infraestrutura e banco de dados.
R8	Confirmar ou criar o aviso de privacidade e o procedimento de atendimento, com canal, responsáveis e acompanhamento das solicitações.	Controlador e encarregado ou responsável pelo canal de privacidade.

Ordem inicial de tratamento: R1 e R2 devem ser tratados antes do uso de dados reais.

6. Retenção e atendimento ao titular

Conjunto	Situação observada	Decisão a documentar
Cadastro pendente	Sem prazo identificado	Prazo após cadastro/inatividade, aviso e descarte.
Cadastro autorizado/ Cognito	Sem prazo identificado	Encerramento de conta, desvinculação e conservação justificada.
Reservas expiradas/ canceladas	Status muda; campos permanecem	Prazo após expiração/cancelamento e destino de endereço/CEP.
Vendas/pagamentos	Sem prazo identificado	Separar dados necessários a obrigações de dados dispensáveis; indicar norma, evento inicial e prazo aplicável.
Logs/Kafka/cópias	Uma semana no grupo de logs; demais prazos não confirmados	Retenção efetiva, acessos, exportações e propagação do descarte.

Registrar e-mail de contato funcionario@carsgalore.com de Funcionário, verificação proporcional da identidade e processo de busca/correção/descarte nos três bancos, Cognito e demais destinos. Não prometer exclusão integral quando houver conservação justificada. Referência: LGPD, arts. 15–18.

7. Conclusão e próximos passos

7.1. Conclusão da avaliação

O relatório identifica os responsáveis e o contexto acadêmico do projeto, descreve os dados tratados e suas finalidades e apresenta os controles existentes e os riscos aos titulares. As justificativas de coleta estão registradas na seção 3; as medidas de proteção e a avaliação dos riscos estão nas seções 4 e 5.

Os controles identificados incluem autenticação e restrição de acesso, verificações de titularidade, mecanismos de integridade dos registros, criptografia do banco, armazenamento de credenciais em serviço de segredos e retenção de logs por sete dias. Ainda há riscos relacionados às credenciais dos usuários, à comunicação entre os componentes, à exposição de dados, à recuperação dos registros e à conservação das informações.

7.2. Acompanhamento das melhorias

O acompanhamento deve se concentrar nas ações já descritas no relatório:

- **Segurança e integridade:** executar as melhorias da seção 5, priorizando a substituição da senha baseada no CPF (R1) e a habilitação de HTTPS (R2) antes do uso de dados reais.
- **Retenção e atendimento:** definir os prazos ainda não identificados na seção 6 e os procedimentos de descarte e atendimento pelo canal informado no documento.
- **Verificação dos resultados:** registrar o responsável, o prazo e a evidência de conclusão de cada ação. Após as melhorias, reavaliar os riscos que permanecem e registrar as decisões do controlador.

A descrição de uma melhoria neste relatório não comprova sua implementação. Seu acompanhamento deve refletir a situação efetiva de cada ação.

7.3. Revisão do relatório

Atualizar o RIPD após a implementação das melhorias e sempre que houver mudanças nos dados coletados, nas finalidades, nos serviços, nas integrações ou no público atendido, bem como após incidentes relevantes. Cada revisão deve registrar a data, o responsável e as alterações que afetam a avaliação dos riscos.